

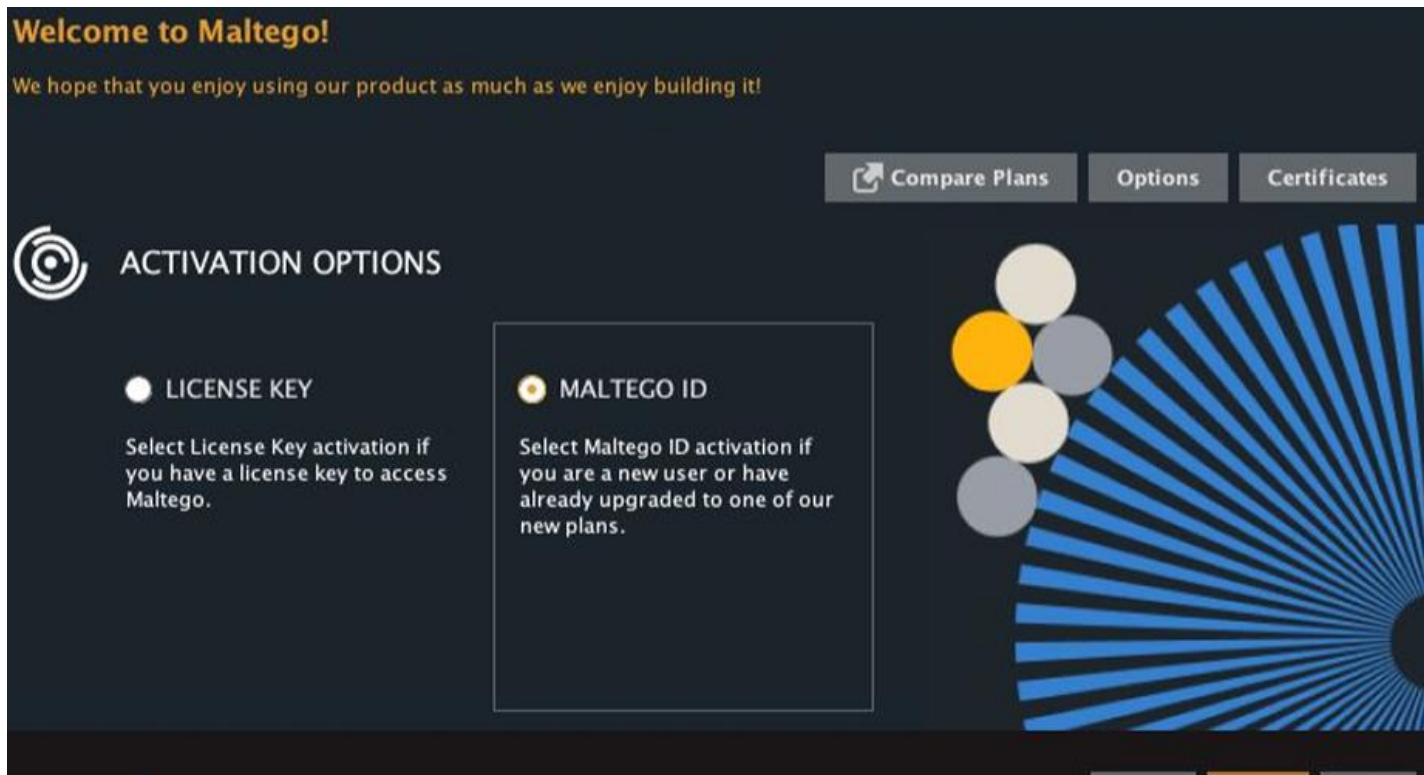
Maltego Installazione e Primo Avvio

Installazione e Configurazione di Maltego

Prima di avviare la ricognizione, è stato installato e configurato Maltego Desktop Client (Community Edition 4.7.0). Di seguito i passaggi seguiti.

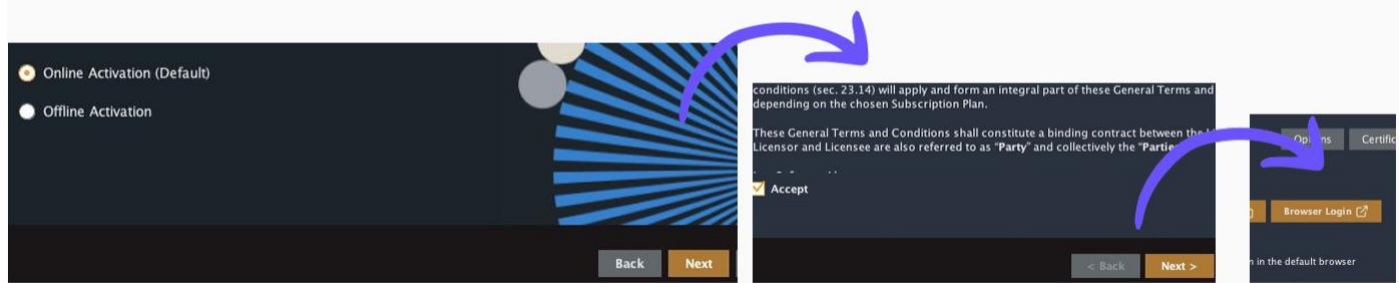
Scelta della modalità di attivazione

Al primo avvio, Maltego richiede di scegliere il metodo di attivazione: License Key oppure Maltego ID per i nuovi utenti o chi utilizza un piano gratuito/Community. Ho selezionata l'opzione Maltego ID.



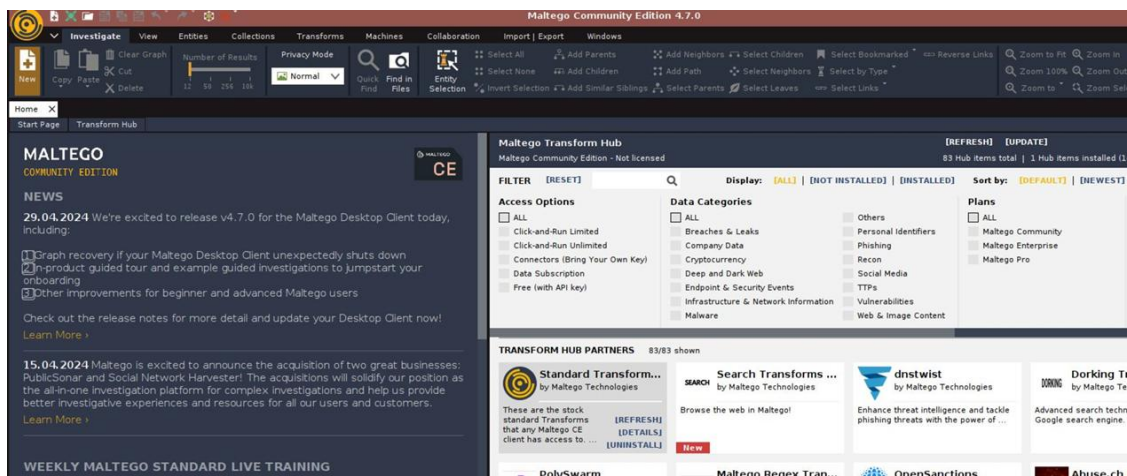
Attivazione online e login

Con l'attivazione online ho accettato i Termini e Condizioni generali del servizio, per poi completare il login tramite browser, che autentica il client desktop con l'account Maltego ID.

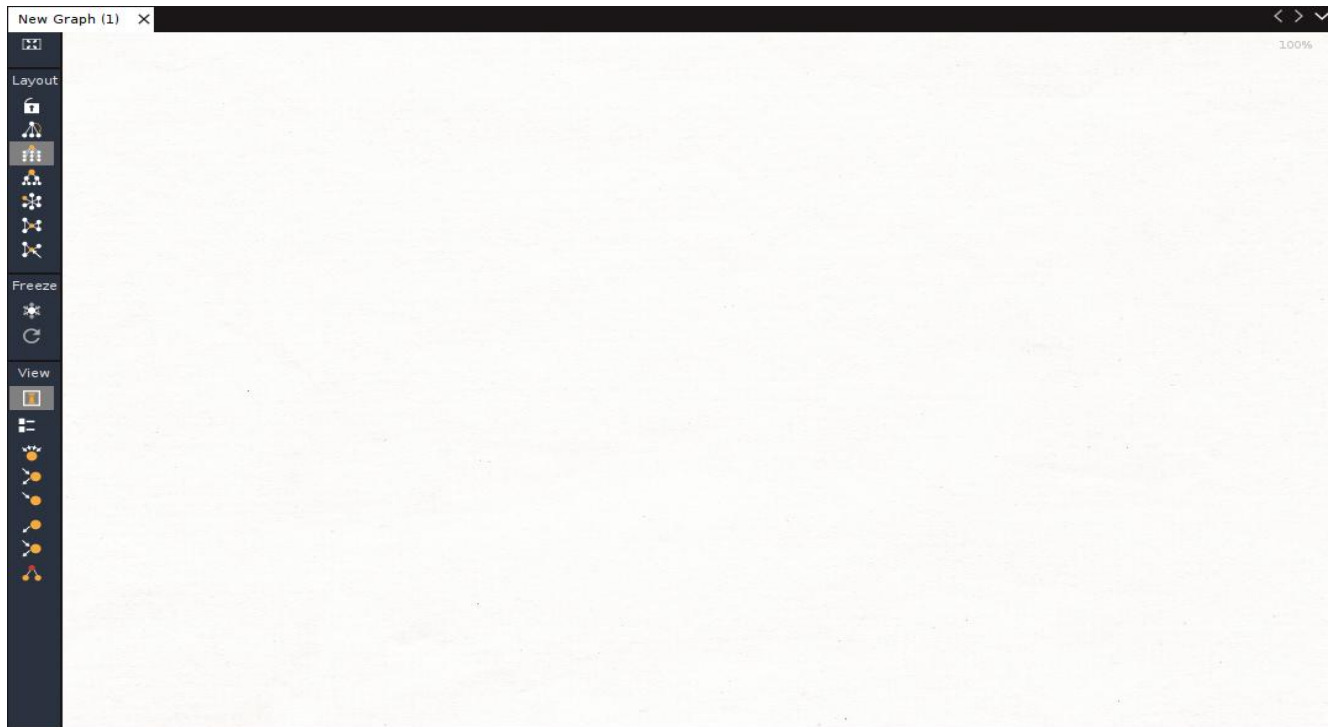


Ambiente pronto — Transform Hub

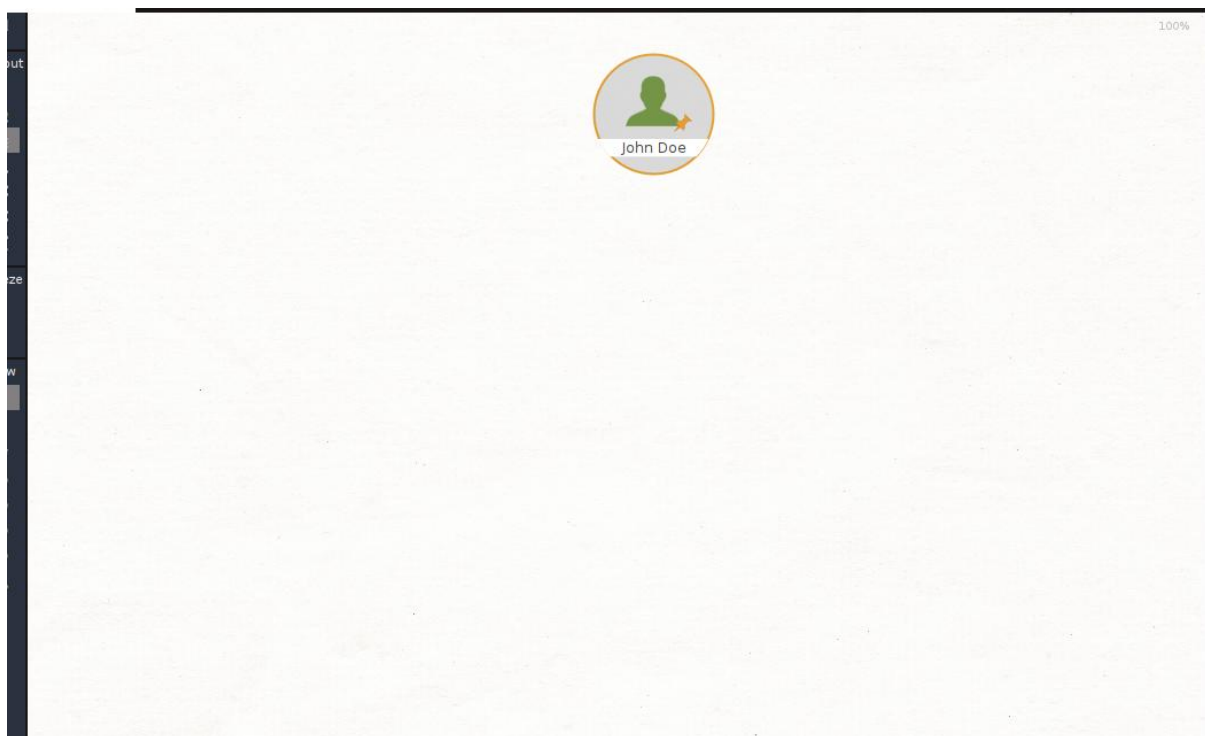
Completata l'attivazione, si accede all'interfaccia principale di Maltego Community. Dalla schermata Start Page è visibile il Transform Hub, da cui sono stati verificati/installati i set di trasformazioni necessari per le query DNS, IP e Whois utilizzate nella ricognizione.



Maltego Graph Desktop: apertura dell'ambiente di lavoro.



Creazione di un nuovo grafo.



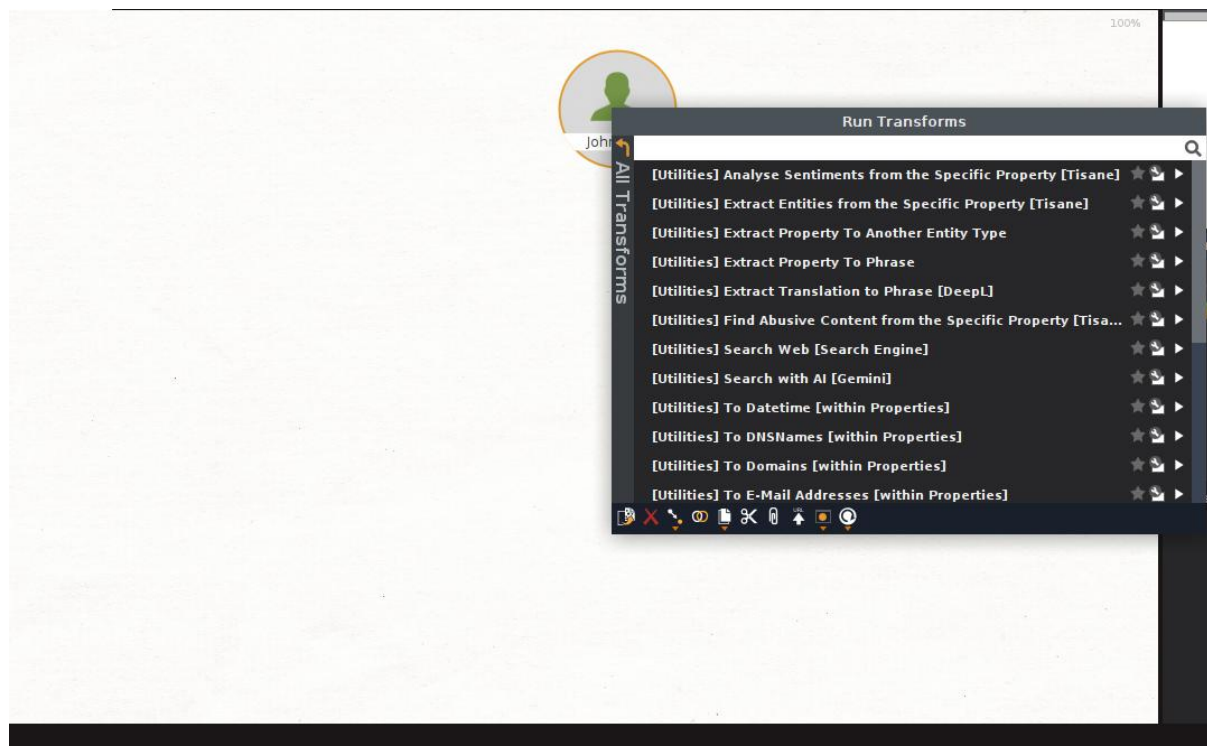
Metodologia

La raccolta è stata condotta rispettando i principi dell'OSINT passivo:

- Nessuna connessione diretta stabilita con i server del target oltre alle normali richieste DNS/WHOIS pubbliche
- Utilizzo esclusivo di fonti pubbliche: registri DNS, database WHOIS, motori di ricerca, pagine pubblicate dall'azienda stessa
- Nessun tentativo di autenticazione, exploit o accesso a risorse non pubblicamente linkate

Strumenti utilizzati: dig/nslookup e whois per DNS/WHOIS, Google Dorking per l'individuazione di documenti pubblici, Maltego per la mappatura visiva delle entità e delle relazioni, uno script Python custom con integrazione dell'API Gemini per l'analisi automatica dei dati raccolti.

Inserimento dell'entità John Doe (Recordgo Mobility) nel grafo.



Parte 2 Esercizio Osint

Reconnaissance OSINT e analisi passiva di Record go Mobility

Obiettivo dell'esercitazione

L'obiettivo di questa esercitazione è effettuare una raccolta di informazioni tramite tecniche di **OSINT (Open Source Intelligence)**, utilizzando esclusivamente fonti pubblicamente disponibili.

L'attività viene svolta in modalità **passiva**, senza eseguire scansioni intrusive, tentativi di autenticazione o attività di sfruttamento dei sistemi.

L'azienda scelta come caso di studio è dove lavoro attualmente:

Record go Mobility

Record go Mobility opera nel settore della mobilità e del noleggio di veicoli. Dalle informazioni pubblicamente disponibili, l'azienda dichiara una presenza in diversi Paesi europei e dispone di una rete di sedi dedicate al noleggio.

Per l'analisi tecnica viene utilizzato il dominio pubblico associato all'azienda:

recordrentacar.com

Metodologia

La reconnaissance è stata suddivisa nelle seguenti attività:

- Identification del Dominio;
- interrogazioni DNS;
- consultazione delle informazioni WHOIS;
- Google Dorking;
- individuazione di eventuali documenti pubblicamente indicizzati;
- ricerca di eventuali directory indicizzate;
- valutazione dei risultati;
- proposta di rappresentazione delle entità attraverso Maltego;

eventuale automazione della raccolta tramite Python e analisi tramite intelligenza artificiale.

Durante l'attività sono state utilizzate esclusivamente informazioni accessibili pubblicamente.

Identificazione del dominio

Come primo passo è stato individuato il dominio utilizzato pubblicamente da Record go Mobility.

Il sito indicato pubblicamente dall'azienda è:

recordrentacar.com

La presenza del dominio è confermata anche dal profilo pubblico dell'azienda, che riporta recordrentacar.com come sito web.

Il dominio rappresenta quindi il punto di partenza dell'attività di reconnaissance.

Analisi DNS Record

La prima command effettuata riguarda il record:

```
dig recordrentacar.com
```

In alternativa può essere utilizzato:

```
nslookup recordrentacar.com
```

Il record A permette di individuare l'indirizzo IPv4 associato al dominio.

Osservazione

```
nslookup recordrentacar.com
```

```
(kali㉿kali)-[~]  
$ nslookup recordrentacar.com  
Server:      192.168.1.1  
Address:     192.168.1.1#53  
  
Non-authoritative answer:  
Name:   recordrentacar.com  
Address: 104.20.47.57  
Name:   recordrentacar.com  
Address: 172.66.148.98  
Name:   recordrentacar.com  
Address: 2606:4700:10::ac42:9462  
Name:   recordrentacar.com  
Address: 2606:4700:10::6814:2f39
```

```
dig recordrentacar.com
```

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ bash  
(kali@kali)-[~]  
$ dig recordrentacar.com A  
  
;<>> DiG 9.20.27-1-Debian <>> recordrentacar.com A  
;; global options: +cmd  
;; Got answer:  
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 20006  
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags;; udp: 4096  
;; QUESTION SECTION:  
recordrentacar.com. IN A  
  
;; ANSWER SECTION:  
recordrentacar.com. 300 IN A 104.20.47.57  
recordrentacar.com. 300 IN A 172.66.148.98  
  
;; Query time: 272 msec  
;; SERVER: 192.168.1.1#53(192.168.1.1) (UDP)  
;; WHEN: Sun Sep 13 06:36:02 EDT 2026  
;; MSG SIZE rcvd: 79  
  
(kali@kali)-[~]  
$ dig recordrentacar.com AAAA short  
  
;<>> DiG 9.20.27-1-Debian <>> recordrentacar.com AAAA short  
;; global options: +cmd  
;; Got answer:  
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 56048  
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags;; udp: 4096  
;; QUESTION SECTION:  
recordrentacar.com. IN AAAA  
  
;; ANSWER SECTION:  
recordrentacar.com. 300 IN AAAA 2606:4700:10::ac42:9462  
recordrentacar.com. 300 IN AAAA 2606:4700:10::6814:2f39  
  
;; Query time: 300 msec  
;; SERVER: 192.168.1.1#53(192.168.1.1) (UDP)  
;; WHEN: Sun Sep 13 06:37:24 EDT 2026
```

Record DNS NS

Successivamente ho cercato i record NS, usando il command:

```
dig recordrentacar.com NS
```

I record NS permettono di identificare i **Name Server** autorevoli associati al dominio.

Output da documentare

```
(kali@kali)-[~]
$ dig recordrentacar.com NS

; <<>> DiG 9.20.27-1-Debian <<>> recordrentacar.com NS
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 23327
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;recordrentacar.com.                IN      NS

;; ANSWER SECTION:
recordrentacar.com.      86400   IN      NS      jack.ns.cloudflare.com.
recordrentacar.com.      86400   IN      NS      nataly.ns.cloudflare.com.

;; Query time: 239 msec
;; SERVER: 192.168.1.1#53(192.168.1.1) (UDP)
;; WHEN: Sun Sep 13 07:32:58 EDT 2026
;; MSG SIZE rcvd: 101
```

Record DNS MX

Per verificare l'infrastruttura pubblica relativa alla posta elettronica è stata effettuata la seguente command:

```
nslookup recordrentacar.com MX
```

Il record MX indica quali server sono configurati per ricevere la posta destinata al dominio.

Commento:

I restituiti uno o più record MX, questi possono essere utilizzati per identificare il servizio o l'infrastruttura email associata al dominio.

È anche importante limitarsi alla semplice osservazione del record e non effettuare ulteriori attività sui server individuati.

```

(kali@kali)-[~]
$ nslookup --type=Mx recordrentacar.com
** Invalid option: -type=Mx
Server:      192.168.1.1
Address:     192.168.1.1#53

Non-authoritative answer:
Name:   recordrentacar.com
Address: 172.66.148.98
Name:   recordrentacar.com
Address: 104.20.47.57
Name:   recordrentacar.com
Address: 2606:4700:10::6814:2f39
Name:   recordrentacar.com
Address: 2606:4700:10::ac42:9462

(kali@kali)-[~]
$ nslookup -type=MX recordrentacar.com
Server:      192.168.1.1
Address:     192.168.1.1#53

Non-authoritative answer:
recordrentacar.com      mail exchanger = 10 recordrentacar-com.mail.protection.outlook.com.

Authoritative answers can be found from:

```

Record DNS TXT

Ho effettuata anche la ricerca dei record TXT, utilizzando il command:

`dig recordrentacar.com TXT`

```

(kali@kali)-[~]
$ dig recordrentacar.com TXT

;<<>> DiG 9.20.27-1-Debian <<>> recordrentacar.com TXT
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 58517
;; flags: qr rd ra; QUERY: 1, ANSWER: 5, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;recordrentacar.com.      IN      TXT

;; ANSWER SECTION:
recordrentacar.com.      60      IN      TXT      "MS=ms32293063"
recordrentacar.com.      60      IN      TXT      "actalis-dcv=hD4iU7zDm7uKNFgbopX-700CVjc0bia0pa961v3XMFireS2MgX_8CXw
Gs-Qfrn5JlgsKxF7qF0wHfjRrjtQG8ayXT38MqWdIuvbVeS9nA6YZRR-qIpJK3Yr3ZhRMR1gBz5aAQuym6VsytKJ4zzijHA"
recordrentacar.com.      60      IN      TXT      "google-site-verification=UzXVfsjdYboeHwfsd0Ma1fMD0VJf4RD5QoVJW1pNpp
v"
recordrentacar.com.      60      IN      TXT      "google-site-verification=zllb24JwovB5oaURt_Y0BvO5VxabfHSfs-2lyPZUyU
K"
recordrentacar.com.      60      IN      TXT      "v=spf1 ip4:46.24.11.16/28 ip4:81.43.127.147/32 ip4:195.53.76.98/32
include:spf.protection.outlook.com include:mail.zendesk.com include:spf.mandrillapp.com include:spf.mailjet.com -all
"

;; Query time: 104 msec
;; SERVER: 192.168.1.1#53(192.168.1.1) (UDP)
;; WHEN: Sun Sep 13 07:48:06 EDT 2026
;; MSG SIZE rcvd: 606

```

WHOIS

La seconda parte dell'analisi riguarda il servizio WHOIS.

Il comando utilizzato è:

```
whois recordrentacar.com
```

Lo scopo è ottenere informazioni amministrative e registrative associate al dominio.

Tra le informazioni che possono essere disponibili troviamo:

- dominio;
- registrar;
- date di registrazione;
- data di scadenza;
- stato del dominio;
- Name Server;
- eventuali informazioni relative al registrante, quando pubblicamente disponibili.

```
(kali㉿kali)-[~]  
$ whois recordrentacar.com  
Domain Name: RECORDRENTACAR.COM  
Registry Domain ID: 44740650_DOMAIN_COM-VRSN  
Registrar WHOIS Server: whois.eurodns.com  
Registrar URL: http://www.EuroDNS.com  
Updated Date: 2025-11-16T08:25:04Z  
Creation Date: 2000-11-22T12:57:16Z  
Registry Expiry Date: 2026-11-22T12:57:16Z  
Registrar: EuroDNS S.A.  
Registrar IANA ID: 1052  
Registrar Abuse Contact Email: legalservices@eurodns.com  
Registrar Abuse Contact Phone: +352.27220150  
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited  
Name Server: JACK.NS.CLOUDFLARE.COM  
Name Server: NATALY.NS.CLOUDFLARE.COM  
DNSSEC: unsigned  
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/  
>>> Last update of whois database: 2026-09-13T11:12:36Z <<<  
  
For more information on Whois status codes, please visit https://icann.org/epp
```

I dati devono essere verificati al momento dell'esercitazione perché le informazioni WHOIS possono cambiare nel tempo.

Google Dorking

Ho anche eseguite le seguenti query mirate per individuare documenti o directory esposte:

```
site:recordrentacar.com filetype:pdf
site:recordrentacar.com intitle:"index of"
site:recordrentacar.com inurl:admin
site:recordrentacar.com ext:env OR ext:log OR ext:sql
```

Questa ricerca permette di individuare eventuali documenti PDF indicizzati appartenenti al dominio.

Durante la verifica devono essere annotati:

- numero approssimativo dei risultati;
- titoli dei documenti;
- URL pubblici;
- eventuale contenuto rilevante.

Un documento trovato può essere classificato, ad esempio, come:

Informazione pubblica / documentazione aziendale

e non deve essere considerato automaticamente una vulnerabilità.

Ricerca di documenti DOC/DOCX

Sono state utilizzate anche le seguenti query:

```
site:recordrentacar.com filetype:doc
```

e:

```
site:recordrentacar.com filetype:docx
```

L'obiettivo è verificare se siano presenti documenti Microsoft Word pubblicamente indicizzati.

Ricerca di file XLS/XLSX

Per verificare l'eventuale presenza di fogli di calcolo:

```
site:recordrentacar.com filetype:xls
```

```
site:recordrentacar.com filetype:xlsx
```

Questa ricerca è particolarmente interessante in un'attività OSINT perché documenti aziendali pubblicamente indicizzati potrebbero contenere informazioni non destinate alla pubblicazione.

In caso di ritrovamento, il contenuto deve essere valutato esclusivamente dal punto di vista della sua esposizione pubblica e nel rispetto dell'autorizzazione disponibile.

Ricerca di directory indicizzate

Una delle query utilizzate è:

```
site:recordrentacar.com intitle:"index of"
```

Questa query cerca pagine indicizzate che presentano nel titolo la stringa index of.

L'eventuale presenza di un risultato può indicare una directory listing pubblicamente visibile.

Importante

La presenza di un index of non equivale automaticamente alla presenza di una vulnerabilità.

In questa esercitazione l'obiettivo è esclusivamente verificare se Google abbia indicizzato tale contenuto.

Ricerca di pagine amministrative

È possibile effettuare anche una ricerca più generale:

```
site:recordrentacar.com inurl:admin
```

oppure:

```
site:recordrentacar.com inurl:login
```

Queste query vengono utilizzate solamente per verificare se tali URL siano stati pubblicamente indicizzati.

Non devono essere effettuati tentativi di accesso o autenticazione.

Ricerca di informazioni pubbliche sull'azienda

Oltre all'analisi tecnica del dominio, sono state considerate informazioni pubblicamente disponibili sull'azienda.

Le fonti pubbliche descrivono Record go Mobility come un'azienda attiva nel settore del noleggio e delle soluzioni di mobilità, con una presenza internazionale. Il profilo pubblico dell'azienda indica inoltre Castellón de la Plana come sede principale.

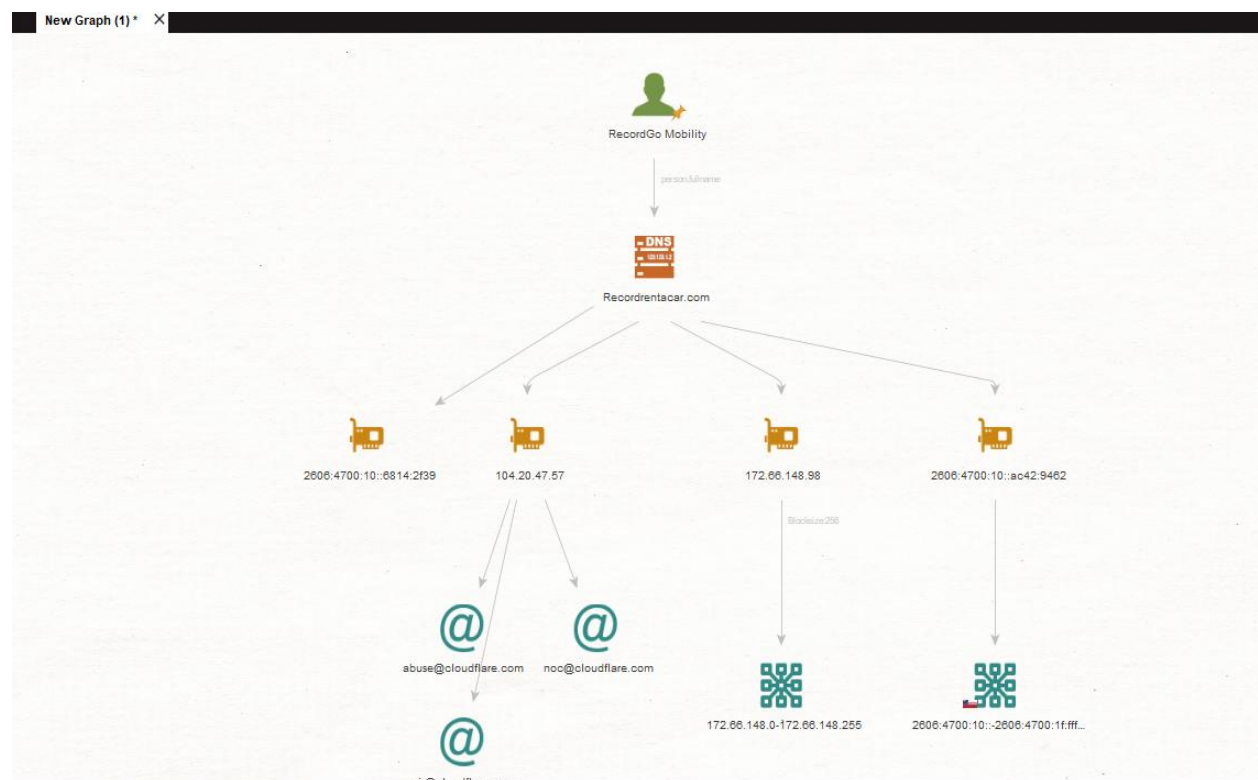
Le informazioni pubbliche relative alle sedi mostrano inoltre una presenza in diverse località europee, tra cui località italiane come Bergamo, Roma, Milano/Bergamo, Bari e Palermo, secondo le pagine pubbliche dell'azienda e delle sue offerte di lavoro.

Queste informazioni possono essere utilizzate successivamente per creare una mappa OSINT.

Mappatura con Maltego

Una delle attività extra previste dall'esercizio consiste nella rappresentazione grafica delle entità scoperte tramite **Maltego**.

La mappa può essere costruita partendo dall'entità principale:



Successivamente è possibile aggiungere le altre informazioni pubblicamente individuate.

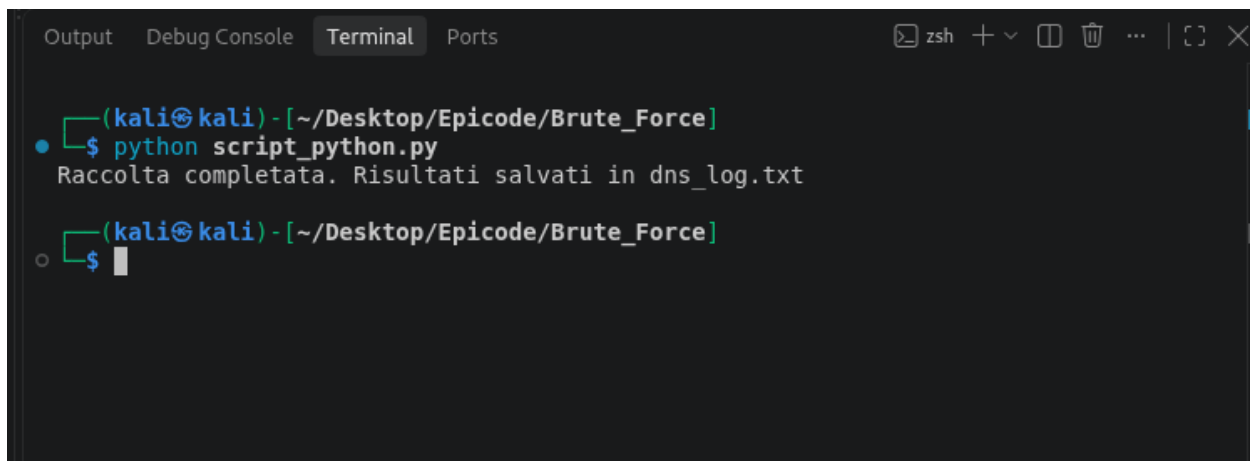
La finalità della mappa è mostrare visivamente come le diverse informazioni OSINT siano collegate tra loro.

Python per la raccolta DNS

Per automatizzare una parte dell'attività è possibile utilizzare Python.

Il seguente script esegue interrogazioni DNS e salva i risultati in un file di log.

```
script_python.py > ...
1  import dns.resolver
2  from datetime import datetime
3
4  domain = "recordrentacar.com"
5
6  record_types = ["A", "AAAA", "MX", "NS", "TXT"]
7
8  log_file = "dns_log.txt"
9
10 with open(log_file, "w", encoding="utf-8") as file:
11
12     file.write("DNS OSINT REPORT\n")
13     file.write(f"Domain: {domain}\n")
14     file.write(f>Date: {datetime.now()}\n")
15     file.write("=" * 60 + "\n\n")
16
17     for record_type in record_types:
18
19         file.write(f"--- {record_type} ---\n")
20
21         try:
22             answers = dns.resolver.resolve(domain, record_type)
23
24             for answer in answers:
25                 file.write(str(answer) + "\n")
26
27         except Exception as error:
28             file.write(f"Nessun risultato: {error}\n")
29
30         file.write("\n")
31
32 print(f"Raccolta completata. Risultati salvati in {log_file}")
33
```

A screenshot of a terminal window with a dark background. The window has tabs at the top labeled 'Output', 'Debug Console', 'Terminal' (which is active), and 'Ports'. The terminal shows a prompt '(kali㉿kali) - [~/Desktop/Epicode/Brute_Force]' followed by the command '\$ python script_python.py'. The output of the command is 'Raccolta completata. Risultati salvati in dns_log.txt'. Below this, the prompt appears again with a cursor, indicating the next command is to be entered.

```
(kali㉿kali) - [~/Desktop/Epicode/Brute_Force]
$ python script_python.py
Raccolta completata. Risultati salvati in dns_log.txt
(kali㉿kali) - [~/Desktop/Epicode/Brute_Force]
$
```

Per utilizzare lo script è necessario installare il modulo DNS:

```
pip install dnspython
```

L'esecuzione avviene tramite:

```
python dns_osint.py
```

Il programma produce: dns_log.txt

contenente i risultati delle interrogazioni DNS.

Valutazione della sicurezza

Dall'attività emerge un principio fondamentale della sicurezza informatica: una grande quantità di informazioni può essere raccolta senza effettuare alcun accesso non autorizzato.

I record DNS, le informazioni WHOIS, le pagine web e i documenti indicizzati costituiscono una superficie informativa che può essere analizzata da un'attività OSINT.

Per un'azienda è quindi importante controllare periodicamente quali informazioni sono pubblicamente disponibili.

In particolare, è consigliabile verificare:

- quali documenti sono indicizzati dai motori di ricerca;
- quali informazioni vengono pubblicate nei record DNS;
- quali informazioni relative all'infrastruttura sono visibili pubblicamente;
- eventuali directory accidentalmente esposte;
- eventuali documenti contenenti informazioni riservate;
- configurazioni DNS relative alla sicurezza della posta elettronica.

Conclusioni

L'esercitazione ha dimostrato come sia possibile effettuare una **ricognizione OSINT passiva** su un'organizzazione utilizzando informazioni pubblicamente disponibili.

Il caso di studio scelto è stato **Record go Mobility**, con particolare attenzione al dominio pubblico `recordrentacar.com`.

L'analisi DNS permette di raccogliere informazioni tecniche relative al dominio, mentre WHOIS consente di ottenere informazioni sulla registrazione del dominio.

Il Google Dorking permette invece di verificare se documenti o directory siano stati indicizzati pubblicamente.

La successiva rappresentazione tramite Maltego consente di trasformare le informazioni raccolte in una mappa delle relazioni tra dominio, DNS, infrastruttura e altre entità pubbliche.

Infine, Python può essere utilizzato per automatizzare la raccolta dei record DNS e creare un log strutturato, mentre un modello di intelligenza artificiale può essere impiegato per sintetizzare e classificare i dati ottenuti.

L'intera attività rimane nell'ambito della **raccolta passiva di informazioni**, senza effettuare attività intrusive sui sistemi dell'azienda.

- Sito web pubblico di Record go Mobility: `recordrentacar.com`
- Profilo pubblico Record go Mobility
- Pagine pubbliche relative alle sedi e alle posizioni lavorative
- DNS pubblico del dominio
- Servizio WHOIS
- Motore di ricerca Google per le verifiche di indicizzazione